

Anonymous Credentials and Privacy in the EU Digital Identity Wallet

Author: Leonardo Rufini

Supervisor: Prof. Ivan Visconti

Academic Year 2025/2026

This report documents the work carried out during my Excellence Path, dedicated to anonymous credentials and their role in the EU Digital Identity (EUDI) Wallet. The work combined a systematic study of the official Architecture and Reference Framework with an extensive survey of the research literature on privacy-preserving credentials and zero-knowledge proofs, and was complemented by a hands-on comparison of the current reference implementations. Its aim was to understand the deployed standard deeply, map the surrounding research landscape, and recognize where the genuine open problems of the field lie. What follows describes the path and the reasoning that guided it.

1. Motivation and objectives

The EUDI Wallet is one of the most ambitious digital-infrastructure projects currently pursued by the European Union: a single application that every citizen will use to identify themselves, share verified attributes, sign documents with legal value, and authenticate to online and offline services across all Member States. Because it is designed to become a mandatory, continent-wide identity layer, the privacy properties it offers are not a secondary feature but a societal concern. Under the guidance of Prof. Visconti, I used my Excellence Path to understand how modern cryptography—and in particular *anonymous credentials*—can, or cannot, deliver those guarantees within the constraints of a real, standardized system. The objective was deliberately open-ended: not to solve a pre-assigned exercise, but to read the standard and its surrounding literature deeply enough to recognize where the genuine open problems lie.

2. Understanding the ecosystem

The first phase was a systematic reading of the Architecture and Reference Framework (ARF). I organized the wallet's functionalities into five families—identification and authentication, exchange of qualified and non-qualified attribute attestations, qualified electronic signatures, pseudonyms, and payments—and, for each, I traced the actors involved, the governing standards, and the cryptographic primitives in play. The ecosystem rests entirely on a Public Key Infrastructure: elliptic-curve cryptography (through the COSE and JOSE frameworks) for mobile-friendly operations, RSA and X.509 certificates for device binding and qualified signatures, and the ETSI **AdES* profiles for document signing. Two presentation protocols dominate: **ISO/IEC 18013-5** for proximity flows and **OpenID4VP** for remote ones, with **SD-JWT VC** and **W3C WebAuthn** covering selective disclosure and pseudonymous authentication respectively.

I also studied the trust model in detail—trusted lists, access certificates, Wallet Unit and Wallet Instance Attestations—and the two orthogonal notions on which the whole security argument rests: *device binding*, which cryptographically ties an attestation to secure hardware (a WSCD) so that it cannot be cloned, and *user binding*, which guarantees that the person presenting the data is its legitimate holder.

3. A critical analysis of the privacy guarantees

Once the mechanics were clear, I shifted from description to critique, and this is where the path became genuinely research-oriented. The wallet realizes selective disclosure through *salted hashes*: the issuer signs a document whose fields are individually hashed, and the holder later reveals only the values (with their salts) that a verifier requires. Reading this mechanism against its intended goals, the analysis surfaces two structural weaknesses:

- **Granularity leakage.** Salted hashes disclose whole fields, not predicates over them. To prove

“I am over 18” one must reveal the entire date-of-birth field; to prove nationality one may end up revealing a full home address. The ARF’s suggested workaround—issuers pre-computing boolean fields such as *over-18: yes/no*—does not scale: it cannot answer “over 19?”, “over 20?”, or any predicate not anticipated at issuance time.

- **Linkability.** Disclosed attributes are bound to a device, the device is bound to the PID, and the PID reveals the legal identity. This chain allows a relying party—and, more subtly, colluding issuers—to re-link supposedly minimal disclosures back to a full identity, collapsing the intended privacy.

Tellingly, the framework itself acknowledges that the “only viable mitigation” is the adoption of **Zero-Knowledge Proofs** (ZKPs), which no component of the ecosystem currently mandates. Recognizing ZKPs as the missing piece was the turning point of the path: it reframed my question from *how does the wallet work?* to *what would it take to make the wallet actually private?*—and motivated the extensive literature survey that followed.

4. Mapping the research landscape

The largest part of the path was a broad reading of the research literature, aimed at understanding why ZKP-based anonymous credentials are not yet part of the deployed standard, and which approaches the community is currently pursuing. The survey spanned foundational papers, recent conference work, and the accompanying open-source prototypes.

The hardware constraint. A recurring theme—articulated most clearly by Lehmann, Sidorenko and Zacharakis in their modular framework *Vision*—is that anti-cloning at the highest Level of Assurance requires the binding key to live inside a Secure Element that never releases it, and that today’s Secure Elements support essentially only ECDSA over the P-256 curve. They cannot natively compute pairing-based signatures (such as BBS) or evaluate ZKPs, so any anonymous-credential scheme must *bridge* a hardware ECDSA signature into a privacy-preserving proof rather than replace it outright.

The zero-knowledge toolbox. I then surveyed the main families of ZK systems and their trade-offs in this specific setting: sigma protocols such as BBS+Schnorr (millisecond proving and very small proofs, but requiring pairing-friendly curves that the hardware lacks); heavily optimized SNARKs (extremely fast, but offering only limited privacy); hybrid “bridging” constructions such as **ZKAttest** and **CDLS**, compatible with the ECDSA keys of existing hardware at the cost of larger proofs; and general-purpose systems such as Groth16, **Ligero** and **STARKs**, able to prove arbitrary statements. A central reference is the Frigo-Shelat **Longfellow** construction, which builds anonymous credentials directly on top of ECDSA using a Ligero-style proof, precisely so as to remain compatible with deployed secure hardware. I also examined the line of work on relaxing the trusted-hardware assumption (*Device-Bound Anonymous Credentials With(out) Trusted Hardware*) and proposals—for instance from the Dyne/Zenroom ecosystem—for mitigating the single-point-of-failure of secure storage through multi-party computation.

The post-quantum dimension. Finally, I followed the post-quantum thread. ECDSA, and the pairing-based schemes typically used for anonymous credentials (BBS, BLS), are broken by Shor’s algorithm, yet migration has been held back by the same hardware constraint and by the relative immaturity and cost of post-quantum ZK circuits. During the path this picture began to change: Google announced that **Android 17** introduces **ML-DSA**—the NIST lattice-based signature standard—into Verified Boot, the Keystore and Play App Signing, exposing post-quantum signatures to developers through the standard TEE interface, while research prototypes such as **zkDilithium** show how lattice signatures can be proved in zero knowledge. Reading these strands together made clear that the field is at an inflection point, with several of its long-standing obstacles simultaneously beginning to loosen.

5. A hands-on comparison of reference implementations

To ground the literature in practice, I obtained and ran the latest versions of two representative codebases and compared them directly. The first was the **EUDI Wallet reference implementation**, which realizes selective disclosure through salted-hash SD-JWT VC and ISO/IEC 18013-5 with no zero-knowledge layer. The second was **Longfellow**, which demonstrates ZK-based anonymous credentials built on ECDSA.

Running the two side by side made the gap between the deployed standard and the research frontier concrete. The reference wallet is a robust, well-engineered system for collecting and presenting signed attestations, but its privacy rests entirely on salted hashes, and it therefore inherits the granularity and linkability limitations analyzed above. Longfellow, by contrast, shows that unlinkable, selectively-disclosing presentations are achievable on top of the very ECDSA keys that existing hardware already supports. The comparison also confirmed, qualitatively, that ZK-based presentation—though heavier than a plain salted-hash disclosure—is approaching practicality on ordinary mobile hardware, which is what makes the whole direction realistic rather than purely theoretical. This exercise turned the survey from an abstract reading exercise into a grounded understanding of what today’s systems can and cannot do.

6. Outcome of the path

Over the course of this Excellence Path I moved from *a standard to be read* to *a research field to be mapped*. I gained a detailed command of the EUDI ecosystem and its standards, a broad view of the anonymous-credential and zero-knowledge literature and of the trade-offs between its competing approaches, and first-hand familiarity with the current reference implementations. Just as importantly, the path clarified where the field’s genuine open problems lie: the integration of zero-knowledge proofs into the standard, the tension between hardware anti-cloning and user privacy, and the looming migration to post-quantum primitives now that secure hardware is beginning to support them. Mapping this terrain—rather than being handed a ready-made question—is precisely what an excellence path should offer, and it is the foundation on which I intend to build my subsequent, more focused work. I am grateful to Prof. Visconti for the guidance and the intellectual freedom that made this exploration possible.

Selected sources

[1] European Commission, *Architecture and Reference Framework (ARF) for the EUDI Wallet*, eudi.dev. [2] ISO/IEC 18013-5:2021, *Mobile driving licence (mDL) application*. [3] OpenID Foundation, *OpenID for Verifiable Presentations (OpenID4VP)*. [4] M. Frigo, a. shelat, *Anonymous Credentials from ECDSA (Longfellow)*, Google. [5] A. Lehmann, A. Sidorenko, A. Zacharakis, *Vision: A Modular Framework for Anonymous Credential Systems*. [6] *Device-Bound Anonymous Credentials With(out) Trusted Hardware*, 2026. [7] ZKAttest and CDLS: hybrid, ECDSA-compatible zero-knowledge proofs. [8] *zkDilithium: zero-knowledge proofs for lattice-based (ML-DSA/Dilithium) signatures*. [9] Google Security Blog, *Post-Quantum Cryptography in Android (ML-DSA, Android 17)*, 2026.